

MEZARLIK BAKIM PLATFORMU

Mühendislik Gereksinim ve Teknik Uygulama Dokümanı

Pilot + MVP → Üretim Ölçeği Mimari Spesifikasyonu

Versiyon 2.0 — Mühendislik Teslim Dokümanı

Hazırlayan: mertasln

Tarih: 24 Ağustos 2026

Bu doküman, pilot analiz raporunda tanımlanan iş modelinin uçtan uca yazılım mimarisini, veri modelini, API tasarımını, altyapı gereksinimlerini, güvenlik/uyumluluk standartlarını ve sprint bazlı teslim planını içerir. Geliştirme ekibi bu dokümanı birebir referans alarak sıfırdan üretime kadar ilerleyebilir.

İçindekiler

1. Doküman Amacı ve Kapsamı
2. Sistem Mimarisi — Genel Bakış
3. Teknoloji Yığını (Tech Stack)
4. Veritabanı Şeması (PostgreSQL)
5. API Tasarımı (REST)
6. Kimlik Doğrulama ve Yetkilendirme
7. Ödeme ve Abonelik Altyapısı
8. Kanıt Toplama ve Doğrulama Sistemi
9. Bildirim Altyapısı
10. Web Frontend — Landing Page ve Sipariş Formu
11. Admin Panel (Operasyon Yönetim Paneli)
12. Saha Mobil WebApp (PWA)
13. Altyapı ve DevOps
14. Güvenlik ve Uyumluluk (KVKK / GDPR / PCI DSS)
15. Test Stratejisi
16. Performans, Ölçeklenebilirlik ve İzleme
17. Operasyonel Kurallar Motoru (SOP → Sistem Eşlemesi)
18. Sprint Bazlı Teslim Planı
19. Ekip Yapısı ve Roller
20. Kabul Kriterleri (Definition of Done) ve Teknik Riskler
21. Ekler

1. Doküman Amacı ve Kapsamı

Bu doküman, "Mezarlık Bakım Platformu — Diaspora & Yerel Hizmet Modeli" pilot analiz raporunda tanımlanan ürünün, mühendislik ekibi tarafından sıfırdan inşa edilebilecek düzeyde ayrıntılandırılmış teknik spesifikasyonudur. Amaç; iş gereksinimleri ile yazılım mimarisi arasındaki tüm boşlukları kapatmak, hiçbir bileşenin yorum ile doldurulmasına gerek bırakmamaktır.

Doküman; sistem mimarisi, teknoloji seçimleri, veritabanı şeması, API sözleşmeleri, kimlik doğrulama/etkilendirme modeli, ödeme ve abonelik altyapısı, kanıt (fotoğraf/geotag) doğrulama sistemi, saha mobil uygulaması, admin paneli, bildirim altyapısı, DevOps/CI-CD, güvenlik ve KVKK/GDPR uyumluluğu, test stratejisi, izleme/analitik, ve sprint bazlı teslim planı olmak üzere 18 ana bölümden oluşur.

Hedef Kitle:

- Backend / Frontend / Mobil mühendisler
- DevOps ve Altyapı mühendisleri
- QA / Test mühendisleri
- Proje yöneticisi ve ürün sahibi
- Güvenlik ve uyumluluk danışmanları

Kabul Kriteri:

Bu doküman "tamam" kabul edilir, eğer bir mühendis hiçbir ek soru sormadan geliştirme ortamını kurabiliyor, veritabanını oluşturabiliyor, ilk API endpoint'ini yazabiliyor ve CI pipeline'ını çalıştırabiliyorsa.

2. Sistem Mimarisi — Genel Bakış

2.1 Mimari Yaklaşım

Pilot ve MVP aşamasında "modüler monolit" (modular monolith) mimarisi önerilir. Mikroservis mimarisi bu ölçekte (50-100 sipariş / 8 hafta) gereksiz operasyonel karmaşıklık ve DevOps yükü getirir. Modüler monolit; kod tabanının servis sınırlarına göre (orders, payments, evidence, users, notifications, partners) net şekilde bölündüğü, ancak tek bir dağıtım birimi (deployment unit) olarak çalışan bir yaklaşımdır. Bu, ileride belirli modüllerin (örn. ödeme, kanıt işleme) bağımsız mikroservislere ayrıştırılmasını ("strangler fig" deseni ile) kolaylaştırır.

2.2 Üst Seviye Bileşen Diyagramı (Metinsel)

- İstemciler: Web (Next.js) — Landing + Sipariş Formu + Müşteri Takip Portalı
- İstemciler: Admin Panel (React SPA) — Operasyon Yöneticisi arayüzü
- İstemciler: Saha Mobil WebApp (PWA, React + Workbox) — Saha Partneri arayüzü
- API Gateway / BFF katmanı: Kimlik doğrulama, rate limiting, request routing
- Uygulama Katmanı (Modular Monolith, Node.js/NestJS): Orders, Payments, Evidence, Users&Auth, Partners, Notifications, Subscriptions, Complaints modülleri
- Asenkron İşler: Message Queue (BullMQ + Redis) — bildirim gönderimi, geotag doğrulama, otomasyon SLA takipleri
- Veri Katmanı: PostgreSQL (birincil OLTP veritabanı), Redis (cache + queue + oturum), S3-uyumlu Object Storage (fotoğraf/kanıt dosyaları)
- Dış Entegrasyonlar: Stripe / PayPal (ödeme), Twilio veya Netgsm (SMS), WhatsApp Business Cloud API, SendGrid/Postmark (e-posta), Google Maps Geocoding API
- Gözlemlenebilirlik: Sentry (hata izleme), Grafana + Prometheus veya Datadog (metrik/log), Metabase (iş zekası / KPI dashboard)

2.3 Veri Akışı Örneği — Sipariş Yaşam Döngüsü

1. Müşteri web formunu doldurur → Frontend, /api/orders endpoint'ine POST atar (draft statüsünde sipariş oluşur).
2. Frontend, Stripe PaymentIntent oluşturmak için /api/payments/intent çağırır; 3D Secure akışı istemci tarafında tamamlanır.
3. Stripe webhook (payment_intent.succeeded) backend'e ulaşır → sipariş statüsü 'Onaylandı' olur → Ops Yöneticisi bildirim kuyruğuna event düşer.
4. Ops Yöneticisi admin panelden konum doğrulaması yapar ve 30 dakika SLA içinde saha partnerine atama yapar (manuel, MVP1) veya sistem otomatik önerir (MVP2).
5. Saha partneri PWA üzerinden görevi 'Başladı' olarak işaretler, en az 2 fotoğraf yükler; her fotoğraf EXIF GPS + sunucu tarafı timestamp ile doğrulanır.
6. Kanıt yüklendiğinde sipariş 'Tamamlandı — Onay Bekliyor' statüsüne geçer; müşteriye otomatik SMS/e-posta/WhatsApp bildirimi gider, 48 saatlik onay penceresi başlar.
7. 48 saat içinde şikayet gelmezse sipariş otomatik 'Kapatıldı' statüsüne geçer ve saha partnerine ödeme hak edışı (payout) kaydı oluşturulur.
8. Şikayet gelirse 'İnceleme' statüsüne geçer, Ops Yöneticisi ve Müşteri Destek ekibi manuel süreç yürütür (ücretsiz tekrar hizmet veya iade).

3. Teknoloji Yığını (Tech Stack)

Katman	Teknoloji	Gerekeçe
Web Frontend	Next.js 15 (React 19, App Router), TypeScript	SEO gerektiren landing page + SSR/ISR desteği, hızlı geliştirme
UI Kit	Tailwind CSS + shadcn/ui	Hızlı, tutarlı, erişilebilir bileşen kütüphanesi
Admin Panel	React 19 + Vite, TanStack Query, TanStack Table	SPA performansı, karmaşık tablo/filtre ihtiyaçları
Saha Mobil Uygulama	PWA (React + Vite + Workbox), Capacitor (opsiyonel native sarmalama)	Tek kod tabanı ile iOS/Android/Web; kamera & GPS erişimi; app store bağımlılığı olmadan hızlı pilot
Backend API	Node.js 22 LTS + NestJS (TypeScript)	Modüler mimari desteği, dependency injection, güçlü tip güvenliği, hızlı ekip verimliliği
Veritabanı	PostgreSQL 16	İlişkisel bütünlük, coğrafi sorgular için PostGIS eklentisi, JSONB esnekliği
ORM	Prisma	Tip güvenli sorgular, migration yönetimi, hızlı geliştirme
Cache & Queue	Redis 7 + BullMQ	Oturum cache, hız sınırlama, asenkron iş kuyruğu (bildirim, geotag doğrulama)
Dosya Depolama	AWS S3 veya DigitalOcean Spaces	Fotoğraf/kanıt dosyaları, CDN entegrasyonu (CloudFront/Spaces CDN)
Ödeme	Stripe (birincil), PayPal (opsiyonel diaspora için)	3D Secure, abonelik (Billing), çoklu para birimi, chargeback yönetimi
SMS	Netgsm (TR yerel) + Twilio (uluslararası diaspora)	Yerel maliyet avantajı + uluslararası kapsama
WhatsApp	WhatsApp Business Cloud API (Meta)	Şablon mesajlar, kanıt bildirimleri, destek kanalı
E-posta	Postmark veya SendGrid	Transaksiyonel e-posta teslim oranı yüksek servisler
Kimlik Doğrulama	JWT (access+refresh) + Passport.js, bcrypt/argon2	Stateless API kimlik doğrulama, güvenli parola hash'leme
Container	Docker + Docker Compose (dev), Kubernetes veya DO App Platform (prod)	Ortam tutarlılığı, kolay ölçeklenebilirlik

Katman	Teknoloji	Gerekçe
CI/CD	GitHub Actions	Otomatik test, build, deploy pipeline
Hosting/Cloud	AWS (eu-central-1) veya DigitalOcean (Frankfurt)	KVKK uyumu için AB/TR yakın veri merkezi
Hata İzleme	Sentry	Frontend + backend hata takibi, performans izleme
Metrik/Log	Grafana + Prometheus + Loki (veya Datadog)	Merkezi izleme ve alarm
BI / KPI Dashboard	Metabase	Self-servis KPI raporlama (dönüşüm oranı, AOV, vb.)

4. Veritabanı Şeması (PostgreSQL)

Aşağıdaki tablolar MVP1 + MVP2 kapsamını tam olarak karşılayacak şekilde tasarlanmıştır. Tüm tablolarda id (UUID, PK), created_at, updated_at, deleted_at (soft delete) standart alanları bulunur; bu alanlar tekrar yazılmamıştır.

4.1 users

Alan	Tip	Açıklama
email	varchar(255) UNIQUE	Giriş için birincil kimlik
phone	varchar(20)	SMS/WhatsApp bildirimleri için, E.164 formatı
password_hash	varchar(255)	argon2id ile hashlenmiş
role	enum	customer ops_manager field_partner support_agent admin
full_name	varchar(255)	-
locale	varchar(10)	tr, en, de vb. — diaspora çoklu dil desteği
is_verified	boolean	E-posta/telefon doğrulaması
kyc_status	enum	field_partner rolü için: pending verified rejected

4.2 field_partners

Alan	Tip	Açıklama
user_id	UUID FK → users	-
national_id_encrypted	text	TC/Pasaport no — AES-256 ile şifreli, ayrı KMS anahtarı
criminal_record_check	boolean + document_url	Sabıka kaydı doğrulama durumu ve belge referansı
insurance_policy_no	varchar(100)	Mesleki sorumluluk sigortası poliçe no
service_cities	text[]	Hizmet verdiği şehirler
rating_avg	numeric(3,2)	Ortalama müşteri puanı
status	enum	onboarding active suspended terminated
contract_signed_at	timestamp	Hizmet sözleşmesi imza tarihi
ethics_training_completed_at	timestamp	Etik/fotoğraf eğitimi tamamlanma tarihi

4.3 cemeteries ve grave_locations

cemeteries: id, name, city, district, municipality_authority, permit_status (enum: pending|approved|rejected), permit_document_url, lat, lng (PostGIS geography point), created_at.

grave_locations: id, cemetery_id (FK), section (ada), plot (parsel), grave_no (mezar no), deceased_name (opsiyonel, hassas veri — ayrı erişim kontrolü), location_note (serbest metin tarif), lat, lng (nullable — saha ekibi tarafından ilk ziyarette doldurulabilir), reference_photo_url.

4.4 orders

Alan	Tip	Açıklama
order_number	varchar(20) UNIQUE	Görünür sipariş no, örn. #MB-2026-00123
customer_id	UUID FK → users	-
grave_location_id	UUID FK	-
service_type	enum	cleaning watering flowers full_package subscription
status	enum	draft pending_payment confirmed assigned in_progress completed_pending_approval closed disputed refunded cancelled
preferred_date	date	-
special_notes	text	Müşteri özel talebi (max 500 karakter)
price_amount	numeric(10,2)	-
currency	varchar(3)	TRY EUR USD GBP
assigned_partner_id	UUID FK → field_partners	nullable
assigned_at	timestamp	SLA takibi için (30 dk hedef)
completed_at	timestamp	-
approval_deadline	timestamp	completed_at + 48 saat
subscription_id	UUID FK	nullable, abonelik siparişleri için

4.5 evidence_photos

Alan	Tip	Açıklama
order_id	UUID FK	-
uploaded_by	UUID FK → users	Saha partneri
photo_type	enum	wide_shot detail_shot before after
file_url	text	S3 object URL
exif_gps_lat / exif_gps_lng	numeric	Fotoğraftan çıkarılan GPS koordinatı
exif_timestamp	timestamp	Fotoğrafın çekildiği an (cihaz saati)
server_received_at	timestamp	Sunucuya ulaştığı an
geotag_validation_status	enum	valid gps_mismatch timestamp_mismatch missing_exif manual_review

Alan	Tip	Açıklama
distance_from_grave_m	numeric	Beklenen mezar konumu ile EXIF GPS arası mesafe (metre)

4.6 payments, subscriptions, payouts

payments: id, order_id (FK), provider (stripe|paypal), provider_payment_intent_id, amount, currency, status (requires_action|succeeded|failed|refunded|chargeback), payment_method_type, three_ds_status, created_at.

subscriptions: id, customer_id (FK), grave_location_id (FK), plan (monthly|annual), price_amount, currency, stripe_subscription_id, status (active|past_due|cancelled), next_billing_date, created_at.

partner_payouts: id, field_partner_id (FK), order_id (FK), amount, status (pending|paid|held_dispute), paid_at, payout_batch_id.

4.7 complaints, notifications, audit_log

complaints: id, order_id (FK), raised_by (FK users), category (quality|disrespect|no_show|other), description, status (open|investigating|resolved_refund|resolved_reservice|rejected), resolution_notes, resolved_at, sla_deadline (completed_at + 48h).

notifications: id, user_id (FK), channel (sms|email|whatsapp|push), template_key, payload (jsonb), status (queued|sent|delivered|failed), sent_at.

audit_log: id, actor_id, actor_role, action, entity_type, entity_id, old_value (jsonb), new_value (jsonb), ip_address, created_at — KVKK/uyumluluk denetimi ve anlaşmazlık çözümü için tüm kritik statü değişikliklerini kapsar (immutable, append-only).

4.8 İndeksleme ve Performans Notları

- orders(status, assigned_partner_id) — Ops panel filtrelerinde en sık kullanılan bileşik indeks
- orders(customer_id, created_at DESC) — Müşteri sipariş geçmişi sorguları
- grave_locations üzerinde PostGIS GIST indeksi (konum bazlı yakınlık sorguları için)
- evidence_photos(order_id) ve audit_log(entity_type, entity_id) indeksleri
- Tüm parasal alanlar numeric(10,2) — asla float kullanılmaz (yuvarlama hatası riski)

5. API Tasarımı (REST)

Tüm endpointler /api/v1 önekiyle başlar, JSON gövde kullanır, kimlik doğrulama Authorization: Bearer <JWT> header'ı ile yapılır. Hata formatı standardize edilmiştir: { "error": { "code": "ORDER_NOT_FOUND", "message": "...", "requestId": "..." } }.

Method	Endpoint	Açıklama	Rol
POST	/auth/register	Müşteri/partner kaydı	Public
POST	/auth/login	JWT access+refresh token üretimi	Public
POST	/auth/refresh	Access token yenileme	Authenticated
POST	/orders	Yeni sipariş oluşturma (draft)	Customer
GET	/orders/:id	Sipariş detayı	Owner/Ops/ Admin
GET	/orders	Filtrelenebilir sipariş listesi (status, city, date)	Ops/Admin
PATCH	/orders/:id/assign	Saha partneri atama	Ops/Admin
POST	/orders/:id/evidence	Kanıt fotoğrafı yükleme (multipart)	Field Partner
POST	/orders/:id/complete	Görevi tamamlandı olarak işaretleme	Field Partner
POST	/orders/:id/approve	Müşteri onayı (48 saat penceresi)	Customer
POST	/orders/:id/complaint	Şikayet açma	Customer
POST	/payments/intent	Stripe PaymentIntent oluşturma	Customer
POST	/payments/webhook	Stripe/PayPal webhook alıcı	Public (imzalı)
POST	/subscriptions	Abonelik oluşturma	Customer
DELETE	/subscriptions/:id	Abonelik iptali	Customer/Admin
GET	/partners/:id/tasks	Saha partnerine atanmış görevler	Field Partner
POST	/partners/onboarding	Saha partneri başvuru/KYC	Field Partner
GET	/kpi/dashboard	Özet KPI verisi (dönüşüm, AOV, vb.)	Admin
GET	/cemeteries/search	Mezarlık adı/şehir bazlı arama (autocomplete)	Public

5.1 Idempotency ve Güvenilirlik

- Ödeme ve sipariş oluşturma endpointleri Idempotency-Key header'ı destekler (çift tıklama/ağ tekrarı koruması).
- Webhook endpointleri imza doğrulaması yapar (Stripe-Signature) ve işlenmiş event ID'leri processed_webhook_events tablosunda tutularak tekrar işleme engellenir.
- Tüm liste endpointleri cursor-based pagination kullanır (limit/offset yerine) — büyük veri setlerinde tutarlılık için.

6. Kimlik Doğrulama ve Yetkilendirme

6.1 Roller ve Yetki Matrisi

Rol	Yetkiler
Customer	Sipariş oluşturma, ödeme, kendi siparişlerini görüntüleme, onay/şikayet açma
Field Partner	Atanan görevleri görüntüleme, kanıt yükleme, görev tamamlama
Ops Manager	Tüm siparişleri görüntüleme/atama, partner onboarding onayı, KPI görüntüleme
Support Agent	Şikayet yönetimi, müşteri iletişimi, sınırlı iade yetkisi (tanımlı limit altında)
Admin	Tam sistem erişimi, kullanıcı/rol yönetimi, finansal raporlar, denetim kayıtları

6.2 Teknik Uygulama

- JWT access token (15 dk ömür) + refresh token (7 gün, httpOnly secure cookie, rotasyonlu)
- NestJS Guards ile route bazlı RBAC (Role-Based Access Control) uygulaması
- Field partner KYC tamamlanmadan (kimlik doğrulama + sabıka kaydı + sözleşme imzası) sisteme görev ataması engellenir — status='active' zorunlu kontrolü
- Hassas alanlara (deceased_name, national_id_encrypted) erişim ayrı bir yetki katmanı ("data classification") ile sınırlandırılır ve her erişim audit_log'a yazılır
- Parola politikası: min 10 karakter, argon2id hash, brute-force koruması için login endpoint'inde rate limiting (5 deneme / 15 dk / IP+hesap)

7. Ödeme ve Abonelik Altyapısı

7.1 Tek Seferlik Ödeme Akışı

9. Frontend, sipariş taslağı oluşturulduktan sonra /payments/intent çağırır → backend Stripe PaymentIntent oluşturur (amount, currency, metadata: order_id).
10. Stripe.js ile istemci tarafında kart bilgisi toplanır (PCI DSS SAQ-A uyumu — kart verisi hiçbir zaman kendi sunucumuza dokunmaz) ve 3D Secure (SCA) akışı otomatik tetiklenir.
11. Başarılı ödeme sonrası Stripe webhook (payment_intent.succeeded) backend'e ulaşır, imza doğrulanır, sipariş 'confirmed' statüsüne geçer.
12. Ödeme reddi/başarısızlığında sipariş 'pending_payment' statüsünde kalır, müşteriye yeniden deneme linki gönderilir (24 saat sonra otomatik iptal).

7.2 Abonelik (Subscription) Akışı

Stripe Billing kullanılarak aylık/yıllık tekrarlayan ödeme planları oluşturulur. Her fatura döneminde invoice.paid webhook'u yeni bir 'order' kaydı otomatik oluşturur (subscription_id ile ilişkili) ve normal sipariş yaşam döngüsüne (atama → kanıt → onay) girer.

7.3 İade, Chargeback ve Diaspora Ödeme Riskleri

- İade: Stripe Refunds API ile kısmi/tam iade; refund_reason zorunlu alan olarak loglanır.
- Chargeback: Stripe Radar kural seti aktif edilir; kanıt fotoğrafları + timestamp + müşteri onay logu, chargeback itirazında (dispute evidence) otomatik pakete eklenir.
- Döviz: Diaspora müşterileri için çoklu para birimi desteği (EUR/USD/GBP) — Stripe otomatik kur dönüşümü; fiyatlandırma TRY bazlı sabitlenip günlük kur ile senkronize edilir.
- Sahte/yüksek riskli işlemler için Stripe Radar risk skoru eşik değeri altında manuel inceleme kuyruğuna düşer (>75 risk skoru).

8. Kanıt Toplama ve Doğrulama Sistemi

Bu sistem, projenin güven inşası açısından en kritik teknik bileşenidir ve aşağıdaki çok katmanlı doğrulama ile tasarlanmalıdır:

8.1 Fotoğraf Yükleme ve EXIF Doğrulama Akışı

13. Saha partneri PWA üzerinden kamera erişimi ile fotoğraf çeker (galeri yüklemesi MVP1'de kapatılır — yalnızca canlı çekim, sahte kanıt riskini azaltmak için).
14. İstemci tarafında fotoğraf, EXIF verisi korunacak şekilde S3 pre-signed URL'e doğrudan yüklenir (backend üzerinden proxy edilmez — performans).
15. Backend, yükleme tamamlandığında S3 event (Lambda veya webhook) ile tetiklenir; sharp/exif kütüphanesi ile EXIF GPS ve timestamp çıkarılır.
16. Çıkarılan GPS koordinatı, grave_locations tablosundaki referans koordinat ile Haversine formülü kullanılarak karşılaştırılır (varsayılan tolerans: 150 metre — mezarlık büyüklüğüne göre yapılandırılabilir).
17. EXIF verisi eksikse (bazı cihazlarda konum izni kapalıysa) veya sapma toleransın üzerindeyse, kayıt 'manual_review' statüsüne düşer ve Ops Yöneticisine bildirim gider.
18. Zaman damgası (timestamp) sunucu tarafı 'server_received_at' ile karşılaştırılır; 24 saatten fazla fark varsa şüpheli olarak işaretlenir (saat dilimi farkları hesaba katılır).

8.2 Kanıt Standartları

- Minimum 2 fotoğraf: 1 geniş açı (mezar ve çevresi), 1 detay çekimi
- Minimum çözünürlük: 1920x1080, orijinal kalite (sıkıştırmasız yükleme, CDN üzerinden sıkıştırılmış türetilmiş versiyon sunulur)
- Saha notu: max 200 karakter, zorunlu alan
- Fotoğraflar S3'te WORM (Write Once Read Many) politikası ile en az 2 yıl saklanır — anlaşmazlık kanıtı olarak

9. Bildirim Altyapısı

Bildirimler BullMQ üzerinden asenkron kuyruğa alınır; her kanal için ayrı worker process çalışır, böylece bir kanaldaki gecikme (örn. SMS sağlayıcı yavaşlığı) diğerlerini etkilemez.

Tetikleyici Olay	Kanal(lar)	Şablon Örneği
Sipariş onaylandı	E-posta + SMS	Sipariş #12345 alındı, tahmini tarih: ...
Saha atandı	WhatsApp (opsiyonel)	Saha ekibi göreve atandı
Görev tamamlandı	E-posta + SMS + WhatsApp	Fotoğraflı raporunuz hazır, 48 saat içinde onaylayın
48 saat onay hatırlatma	SMS (24. saatte)	Onay süreniz 24 saat içinde doluyor
Abonelik yenileme	E-posta	Bir sonraki bakım otomatik planlandı
Şikayet açıldı/çözüldü	E-posta + SMS	Şikayetiniz alındı / çözüme kavuştu

Tüm şablonlar WhatsApp Business API için Meta onaylı 'template message' formatında önceden kayıt edilmelidir (init edilmemiş konuşmalarda serbest metin gönderilemez — Meta politikası).

10. Web Frontend — Landing Page ve Sipariş Formu

10.1 Landing Page Bileşenleri

- Header: Logo, menü (Hakkımızda/Hizmetler/SSS/Giriş), çoklu dil seçici (TR/EN/DE)
- Hero: Başlık + CTA butonu + arka plan görseli (saygılı, sakin ton — pilot dokümanındaki etik hassasiyet ilkesine uygun)
- Hizmet kartları (4 adet): Temizlik / Sulama / Çiçek Ekleme / Periyodik Abonelik — her biri fiyat aralığı ve 'Sipariş Ver' CTA'sı ile
- 3 Adımda Nasıl Çalışır bileşeni (illüstrasyon + kısa metin)
- Güven bölümü: Saha doğrulama rozeti, sigorta bilgisi, %100 iade garantisi, gerçek (izinli) müşteri yorumları
- SSS akordeon bileşeni
- Footer: destek kanalları, yasal linkler (KVKK aydınlatma metni, Mesafeli Satış Sözleşmesi, İptal/İade politikası)

10.2 Sipariş Formu — Adım Adım (Multi-step Form)

19. Adım 1 — Müşteri Bilgileri: ad, soyad, e-posta, telefon (uluslararası format desteği, libphonenumber-js ile doğrulama)
20. Adım 2 — Mezar Bilgisi: şehir seçimi → mezarlık autocomplete (/cemeteries/search) → ada/parsel/mezar no → opsiyonel mevcut fotoğraf yükleme → tarif notu (harita pin'i opsiyonel, Google Maps entegrasyonu)
21. Adım 3 — Hizmet Seçimi: tek seferlik / abonelik / çiçek paketi radio seçimi, fiyat dinamik güncellenir
22. Adım 4 — Tarih ve Notlar: tarih seçici (yalnızca saha kapasitesine göre uygun günler aktif — kapasite API'sinden çekilir), özel talep metin alanı
23. Adım 5 — Ödeme: Stripe Elements gömülü kart formu + KVKK/Hizmet Sözleşmesi onay kutusu (zorunlu, ayrı ayrı checkbox)
24. Son Ekran: Sipariş özeti, takip numarası, destek kanalı linkleri, sipariş takip sayfası linki (giriş gerektirmeden token ile erişim)

10.3 Form Validasyon ve UX Kuralları

- React Hook Form + Zod şema validasyonu (frontend ve backend'de aynı şema paylaşılır — tek kaynak doğruluk)
- Her adımda draft otomatik kayıt (localStorage + backend draft endpoint) — kullanıcı sayfadan ayrılırsa veri kaybolmaz
- Erişilebilirlik: WCAG 2.1 AA uyumu, tüm form alanları klavye ile gezilebilir, ekran okuyucu etiketleri

11. Admin Panel (Operasyon Yönetim Paneli)

11.1 Modüller

- Sipariş Yönetimi: Filtrelenebilir/aranabilir tablo (durum, şehir, tarih, partner), toplu işlem desteği, sipariş detay sayfası (zaman çizelgesi/audit trail görünümü)
- Atama Ekranı: Bekleyen siparişler + müsait saha partnerleri yan yana (kanban veya liste görünüm), tek tıkla atama, SLA sayaç göstergesi (30 dk hedef, renk kodlu uyarı)
- Partner Yönetimi: Onboarding onay akışı (KYC belge inceleme), performans/puan geçmişi, ödeme hak ediş (payout) listesi
- Şikayet Yönetimi: Kanban board (Açık/İnceleniyor/Çözüldü), SLA sayaç, çözüm şablonları
- KPI Dashboard: Dönüşüm hunisi, AOV, tekrarlayan müşteri oranı, şikayet oranı, ortalama SLA süresi — Metabase embed veya native chart (Recharts)
- Kullanıcı & Rol Yönetimi: Admin/Support/Ops kullanıcı CRUD, rol atama
- Mezarlık & İzin Yönetimi: Mezarlık kayıtları, belediye izin statüsü ve belge arşivi

11.2 Teknik Notlar

- TanStack Table ile server-side pagination/sorting/filtering (büyük veri setlerinde performans)
- Gerçek zamanlı güncellemeler için WebSocket (Socket.io) veya polling (30 sn) — yeni sipariş/şikayet bildirimleri
- Tüm kritik aksiyonlar (statü değişikliği, iade onayı) için 'onay modalı' + audit_log kaydı zorunlu

12. Saha Mobil WebApp (PWA)

12.1 Ekranlar

25. Giriş: Telefon no + OTP (SMS) ile kimlik doğrulama (saha partnerleri için parola yerine OTP tercih edilir — düşük teknik okuryazarlık senaryosuna uygun)
26. Görev Listesi: Atanmış görevler kart listesi (adres, mezar konumu, müşteri notu, hizmet tipi, SLA süresi), harita üzerinde günlük rota görünümü
27. Görev Detayı: 'Başla' butonu → konum GPS ile doğrulanır (mezarlığa X metre yakınlık kontrolü, opsiyonel sert kural) → kamera açılır
28. Fotoğraf Çekim Ekranı: Native camera API (getUserMedia / Capacitor Camera plugin), minimum 2 fotoğraf zorunluluğu, çekim sonrası önizleme + yeniden çekme seçeneği
29. Rapor & Tamamlama: Saha notu metin alanı (max 200 karakter) + 'Tamamla' butonu → offline ise local queue'ya alınır, bağlantı gelince otomatik senkronize edilir (Background Sync API)

12.2 Offline-First Yaklaşım

- Service Worker (Workbox) ile görev listesi ve form durumu IndexedDB'de cache'lenir
- Fotoğraflar önce cihazda (IndexedDB/Blob) saklanır, ağ bağlantısı geldiğinde arka planda yüklenir — mezarlıklarda sinyal zayıflığı öngörülerek kritik bir tasarım kararıdır
- Senkronizasyon çakışması durumunda 'son yazan kazanır' + kullanıcıya bilgilendirme

13. Altyapı ve DevOps

13.1 Ortamlar

- local (Docker Compose): geliştirici makinesi, tüm servisler + seed data
- staging: her PR merge sonrası otomatik deploy, QA ve UAT için
- production: manuel onaylı deploy (GitHub Actions environment protection rule)

13.2 CI/CD Pipeline (GitHub Actions)

30. Lint + type-check (ESLint, TypeScript strict mode)
31. Unit test (Jest) — minimum %70 kod kapsamı zorunlu (payment ve evidence modüllerinde %90+)
32. Integration test (Supertest + test veritabanı — Testcontainers ile izole PostgreSQL)
33. Docker image build + container registry'e push (GitHub Container Registry)
34. Staging'e otomatik deploy + Playwright ile smoke E2E test
35. Production'a manuel onay sonrası blue-green veya rolling deploy

13.3 Altyapı Bileşenleri

- Managed PostgreSQL (otomatik günlük yedekleme, point-in-time recovery, 30 gün saklama)
- Managed Redis (Elasticache veya DO Managed Redis)
- Object Storage + CDN (fotoğraflar için CloudFront/Spaces CDN, önbellek süresi 1 yıl, immutable dosya adlandırma)
- Load Balancer + minimum 2 backend instance (yüksek erişilebilirlik)
- Secrets Management: AWS Secrets Manager veya Doppler — API anahtarları asla kod/env dosyasında düz metin tutulmaz
- Altyapı-as-Code: Terraform ile tüm bulut kaynakları versiyon kontrolünde tanımlanır

13.4 Yedekleme ve Felaket Kurtarma

- RPO (Recovery Point Objective): 1 saat — veritabanı sürekli WAL arşivleme
- RTO (Recovery Time Objective): 4 saat — staging ortamı prod'a hızlı promote edilebilir yapı
- Aylık felaket kurtarma tatbikatı (restore test) önerilir

14. Güvenlik ve Uyumluluk (KVKK / GDPR / PCI DSS)

14.1 Veri Sınıflandırması

Sınıf	Örnek Veri	Koruma Önlemi
Kritik	Kart bilgisi	Sistemimize hiç girmez — Stripe Elements/tokenization (PCI DSS SAQ-A)
Hassas	TC/Pasaport no, sabıka kaydı	AES-256 alan bazlı şifreleme, ayrı KMS anahtarı, erişim audit'i
Kişisel	Ad, e-posta, telefon, ölen kişi adı	TLS 1.3 transit, at-rest disk şifreleme, erişim RBAC ile sınırlı
İş Verisi	Sipariş, fotoğraf, statü	Standart erişim kontrolü + audit log

14.2 KVKK Uyumluluk Gereksinimleri

- Açık rıza metni ve aydınlatma metni sipariş formunda ayrı checkbox olarak sunulur (önceden işaretli olamaz)
- Veri işleme envanteri ve VERBİS kaydı (gerekirse şirket büyüklüğüne göre) hukuk danışmanı ile teyit edilmeli
- 'Unutulma hakkı' — müşteri talebiyle kişisel verilerin silinmesi/anonimleştirilmesi için API + admin süreç (finansal kayıtlar yasal saklama süresi boyunca anonimleştirilmiş biçimde tutulur)
- Ölen kişi bilgisi (deceased_name) üçüncü kişi verisi olabileceğinden ekstra hassasiyetle işlenir, pazarlama amacıyla asla kullanılmaz
- Diaspora (AB) müşterileri için GDPR madde 44+ kapsamında veri aktarım mekanizması (Standard Contractual Clauses) değerlendirilmeli — veri merkezi AB/TR yakınında seçilerek risk azaltılır

14.3 Uygulama Güvenliği

- OWASP Top 10 kontrol listesi her sprint sonunda gözden geçirilir
- Rate limiting: genel API 100 req/dk/IP, auth endpointleri 5 req/15dk
- Girdi doğrulama: tüm endpointlerde Zod/class-validator şema doğrulaması, SQL injection Prisma ORM ile parametrize sorgular sayesinde önlenir
- Dosya yükleme: MIME type + magic byte kontrolü, maksimum dosya boyutu (15MB), virüs taraması (ClamAV) opsiyonel
- Pilot öncesi bağımsız penetrasyon testi ve pilot sonrası (production ölçeğe geçmeden önce) ikinci bir tur önerilir
- Güvenlik başlıkları: CSP, HSTS, X-Frame-Options, CSRF token (form tabanlı işlemlerde)

15. Test Stratejisi

Test Türü	Araç	Kapsam
Unit Test	Jest	Servis katmanı iş mantığı, fiyat hesaplama, geotag mesafe hesaplama
Integration Test	Jest + Supertest + Testcontainers	API endpointleri, veritabanı etkileşimi
E2E Test	Playwright	Kritik kullanıcı akışları: sipariş oluşturma→ödeme→onay, saha kanıt yükleme
Yük Testi	k6	Kampanya dönemleri (Anneler Günü vb.) için eş zamanlı sipariş yükü simülasyonu
Güvenlik Testi	OWASP ZAP + manuel pentest	Pilot öncesi zorunlu
Kabul Testi (UAT)	Manuel, Ops ekibi ile	Gerçek senaryo ile pilot öncesi son onay

Ödeme ve kanıt doğrulama modülleri, sistemin güven omurgası olduğundan, minimum %90 test kapsamı ve her PR için zorunlu code review (en az 1 onay) kuralı uygulanır.

16. Performans, Ölçeklenebilirlik ve İzleme

16.1 Performans Hedefleri

Metrik	Hedef
Landing page LCP (Largest Contentful Paint)	< 2.5 sn (mobil 4G)
API p95 yanıt süresi	< 300 ms (fotoğraf yükleme hariç)
Fotoğraf yükleme (S3 direct)	< 5 sn / fotoğraf (ortalama 4G bağlantı)
Sistem uptime	%99.5 (pilot), %99.9 (üretim ölçeği hedefi)

16.2 İzleme ve Alarm

- Sentry: frontend + backend hata oranı, kritik hata için Slack/e-posta anlık alarm
- Grafana Dashboard: API gecikme, hata oranı, kuyruk derinliği (BullMQ), veritabanı bağlantı havuzu doluluğu
- İş metrikleri alarmı: SLA aşımı (30 dk atama, 48 saat onay) için otomatik Ops bildirimi
- Uptime izleme: harici servis (UptimeRobot/Better Uptime) ile dış dünyadan erişilebilirlik kontrolü

17. Operasyonel Kurallar Motoru (SOP → Sistem Eşlemesi)

Pilot dokümanındaki SOP adımlarının yazılımda birebir nasıl uygulanacağı aşağıda eşlenmiştir; bu, iş kurallarının kodda 'gizli varsayım' olarak kalmaması için referans tablodur.

SOP Kuralı	Sistem Uygulaması
30 dk içinde saha partnerine atama	assigned_at alanı + cron job her 5 dk kontrol, aşımda Ops'a eskalasyon bildirimi
Min 2 fotoğraf, geotag+timestamp zorunlu	evidence_photos tablosu kısıtı + backend validasyonu, eksikse 'complete' endpoint 422 döner
Max 200 karakter saha notu	DB CHECK constraint + frontend maxLength
48 saat onay/şikayet penceresi	approval_deadline alanı + cron job otomatik 'closed' statüsüne geçiş
Saha personeli TC/Pasaport + sabıka + eğitim zorunlu	field_partners.status='active' olabilmesi için tüm KYC alanları dolu olmalı (DB trigger veya servis katmanı kontrolü)
Ön ödeme + 3D Secure zorunluluğu	Stripe PaymentIntent confirmation_method='automatic', requires_action akışı zorunlu

18. Sprint Bazlı Teslim Planı

18.1 Sprint 0 — Kurulum (1 Hafta)

- Repo yapısı (monorepo — Turborepo/Nx önerilir: apps/web, apps/admin, apps/field-pwa, apps/api, packages/shared-types)
- CI/CD pipeline iskeleti, staging ortamı, veritabanı migration altyapısı (Prisma)
- Tasarım sistemi (Figma → Tailwind token eşlemesi), temel kimlik doğrulama akışı

18.2 Sprint 1-2 — Çekirdek Sipariş Akışı (2 Hafta)

- Landing page + sipariş formu (5 adım)
- Sipariş/mezar/müşteri veritabanı şeması + API
- Stripe ödeme entegrasyonu (test modu)

18.3 Sprint 3-4 — Operasyon ve Saha (2 Hafta)

- Admin panel: sipariş listesi + atama ekranı
- Saha PWA: giriş, görev listesi, kanıt yükleme + EXIF doğrulama
- Bildirim altyapısı (e-posta+SMS temel şablonlar)

18.4 Sprint 5 — Güven Katmanı ve Uyumluluk (1 Hafta)

- Şikayet yönetimi akışı
- KVKK metinleri, audit log, güvenlik sertleştirilmesi (rate limiting, header'lar)
- E2E test paketi + pentest hazırlığı

18.5 Sprint 6 — Pilot Öncesi Sertleştirme (1 Hafta)

- Yük testi, hata izleme kurulumu, KPI dashboard (Metabase)
- UAT — Ops ekibi ile gerçek senaryo provaları
- Production deploy + izleme alarmları aktif

18.6 Sprint 7-8 — Canlı Pilot ve İterasyon (2 Hafta)

- Canlı sipariş akışı izleme, günlük bug-fix döngüsü
- KPI'ların haftalık gözden geçirilmesi (dönüşüm, AOV, şikayet oranı)
- MVP2 kapsamının (abonelik, mobil GPS doğrulama, otomasyon) backlog'a hazırlanması

18.7 MVP2 ve Sonrası (Pilot Sonuçlarına Göre)

- Rota optimizasyonu (Google OR-Tools veya Mapbox Optimization API)
- Otomatik atama algoritması (partner müsaitlik + mesafe skoru)
- Çoklu dil/para birimi genişletmesi, B2B belediye portalı

19. Ekip Yapısı ve Roller

Rol	Sorumluluk	Tahmini Kişi-Hafta (8 haftalık pilot)
Tech Lead / Backend	Mimari kararlar, API, veritabanı, ödeme entegrasyonu	8
Frontend Mühendisi	Landing page, sipariş formu, admin panel	8
Mobil/PWA Mühendisi	Saha uygulaması, offline senkronizasyon	6
DevOps Mühendisi	CI/CD, altyapı, izleme (yarı zamanlı olabilir)	3
QA Mühendisi	Test planı, otomasyon, UAT koordinasyonu	4
Ürün Yöneticisi	Kapsam yönetimi, Ops ekibiyle koordinasyon	8
Güvenlik/Uyumluluk Danışmanı	KVKK, pentest koordinasyonu (dış kaynak olabilir)	1-2

20. Kabul Kriterleri (Definition of Done) ve Teknik Riskler

20.1 Genel Definition of Done

- Kod code review'dan geçmiş ve en az 1 onay almış
- Unit + integration testler yazılmış ve CI'da yeşil
- Hata senaryoları (400/401/403/404/422/500) için test edilmiş ve kullanıcı dostu hata mesajları dönüyor
- Erişilebilirlik ve mobil responsive kontrolü yapılmış (frontend işleri için)
- İlgili audit_log kaydı doğrulanmış (statü değiştiren işlemler için)
- Staging ortamında QA onayı alınmış

20.2 Öne Çıkan Teknik Riskler ve Azaltım

Risk	Azaltım
Sahte/manipüle edilmiş kanıt fotoğrafı	EXIF+GPS+timestamp çapraz doğrulama, canlı çekim zorunluluğu, şüpheli kayıtlarda manuel inceleme kuyruğu
Mezarlıklarda zayıf internet bağlantısı	PWA offline-first mimari, arka planda senkronizasyon
Ödeme sağlayıcı kesintisi	Stripe + PayPal çift entegrasyon, devre kesici (circuit breaker) deseni
Hassas veri sızıntısı (TC no, ölen kişi bilgisi)	Alan bazlı şifreleme, en az yetki prensibi, düzenli güvenlik denetimi
Kampanya döneminde ani trafik artışı (Anneler Günü)	Yatay ölçeklenebilir backend, yük testi ile önceden doğrulama, CDN önbellekleme
Saha partneri kötü uygulaması	KYC zorunluluğu, puanlama sistemi, audit trail, sözleşmesel ceza mekanizması sisteme statü (suspended/terminated) olarak yansıtılır

21. Ekler

21.1 Örnek Ortam Değişkenleri (.env)

DATABASE_URL, REDIS_URL, JWT_ACCESS_SECRET, JWT_REFRESH_SECRET, STRIPE_SECRET_KEY, STRIPE_WEBHOOK_SECRET, S3_BUCKET, S3_ACCESS_KEY, S3_SECRET_KEY, WHATSAPP_BUSINESS_TOKEN, NETGSM_API_KEY, SENTRY_DSN, KMS_KEY_ID_PII, GOOGLE_MAPS_API_KEY.

21.2 Örnek Sipariş Durum Makinesi (State Machine)

draft → pending_payment → confirmed → assigned → in_progress → completed_pending_approval → closed | disputed. Yan dallar: pending_payment → cancelled (24 saat ödeme yapılmazsa), completed_pending_approval → disputed → refunded | reservice → closed.

21.3 Referans

Bu doküman, 03 Ağustos 2026 tarihli 'Mezarlık Bakım Platformu — Pilot + MVP Proje Analizi' (v1.0) raporundaki iş gereksinimlerinin teknik uygulamasıdır; ilgili pazarlama, hukuki sözleşme başlıkları ve KPI tanımları için o doküman referans alınmalıdır.

— Doküman Sonu —